

PROPOSED INTEGRATED DRAFT — NOT APPROVED*For Council review only · Not authorised, effective or operational until formally approved*

The Council

AI Security Review Checklist

Required for High and Critical risk AI systems and for action-capable agents at any risk tier, with the depth proportionate to the authority and consequence, before governance approval (Playbook §3.10.1–§3.10.2). Assesses the system against The Council's cyber security framework and the AI-specific security risks defined in Playbook §4.3.4, in line with Principle 7: Privacy and Security (§4.2.7). Complete blue-shaded cells and attach supporting evidence. This checklist supplements, and does not replace, existing IT security assurance processes.

1. System under review

System identity	See AI Register (AIG-INV-04) under the AIR-ID below.
UC-ID(s) / configuration assessed	Purpose/data/permissions; AGPI priority ____; risk tier ____.
AIR-ID	As recorded in the AI Register
Risk classification	Low / Medium / High / Critical; record agency tier where action-capable
Reviewer / role	e.g. Information Security, Cyber Security Representative
Review date	

Security applicability — assess actual deployment, data, interfaces and permissions for each named UC-ID. Share platform controls only after applicability is checked; residual risk remains use-specific. Apply agent/action controls only when this configuration can take actions.

2. Cyber security framework alignment (§4.2.7, Ch.5 AI Policy)

Review question	Yes	No	N/A	Evidence / notes
Will the system be deployed and operated within the Council's existing cyber security framework and Information Security Policy? (§5.1.3, §4.7.4)	☐	☐	☐	
Are security controls proportionate to the sensitivity of the data processed? (§4.2.7)	☐	☐	☐	
Does the supplier hold recognised security certifications (e.g. Cyber Essentials Plus, ISO/IEC 27001), with contractual security commitments in place? If not, describe equivalent independently verifiable controls and evidence. Certification is evidence for assessment, not a substitute for verifying the controls and their scope. (§6.6.2.4)	☐	☐	☐	
Are data handling arrangements confirmed — encryption in transit and at rest, processing/storage locations, retention and deletion? Record residency separately from international-transfer safeguards; UK or adequate-jurisdiction residency alone does not establish that transfer requirements are met.	☐	☐	☐	
Is council or resident data excluded from supplier model training, or subject to explicit agreed terms?	☐	☐	☐	
Are supplier/sub-processor processing locations and international-transfer safeguards verified, including adequacy, IDTA or UK Addendum as applicable?	☐	☐	☐	

3. AI-specific security risks (§4.3.4)

Review question	Yes	No	N/A	Evidence / notes
Adversarial attacks: has the system's exposure to adversarial or manipulated inputs been assessed? (§4.3.4)	☐	☐	☐	
Prompt injection: where the system uses a large language model, are prompt injection risks assessed and mitigated (input handling, output constraints, least-privilege integrations)? (§4.3.4)	☐	☐	☐	
Data poisoning: are training and data pipelines protected against poisoning, with data lineage and provenance documented? (§4.3.4, §4.3.5)	☐	☐	☐	
Model extraction: are controls in place to limit model extraction or misuse via the system's interfaces? (§4.3.4)	☐	☐	☐	
Data exfiltration: where the system integrates with sensitive council data sources, have exfiltration and system-compromise pathways been	☐	☐	☐	

3. AI-specific security risks (§4.3.4)

Review question	Yes	No	N/A	Evidence / notes
assessed and mitigated? (§4.3.4)				
Action capability misuse: where the system can take actions through connected tools, systems or interfaces, are risks of injected or manipulated instructions misusing those action capabilities assessed and mitigated? (§4.3.4)	☐	☐	☐	
Permission scope: is the system's access limited to the least privilege its approved use case requires, with no broader permission scope than necessary? (§4.3.4, §4.7.7)	☐	☐	☐	
Cascading automated actions: are controls in place to prevent an erroneous automated action propagating across connected systems before human intervention is possible (approval thresholds, action logging, suspension capability)? (§4.3.4, §4.7.7)	☐	☐	☐	

4. Access, auditability and resilience

Review question	Yes	No	N/A	Evidence / notes
Is access limited to authorised, individually identifiable accounts, with administrative access controlled and revoked on role change?	☐	☐	☐	
Are system activity and AI-assisted decisions logged sufficiently to support audit, review and challenge? (§6.6.2.3)	☐	☐	☐	
Is there a tested rollback or safe-withdrawal path if the system fails, is compromised, or produces harmful outputs?	☐	☐	☐	
Is the system incorporated into incident response arrangements, with security events recognised as escalation triggers? (§3.10.3)	☐	☐	☐	
Are ongoing security monitoring arrangements defined for the operational lifecycle? (§6.6.2.1)	☐	☐	☐	
Does the supplier operate a vulnerability-disclosure and patch-management process with severity-based remediation deadlines and critical-patch service levels?	☐	☐	☐	
Is current independent security testing available, and are Critical/High findings closed or subject to authorised, time-bound risk treatment?	☐	☐	☐	
Are contractual security-incident notification, evidence-preservation and investigation-cooperation requirements defined?	☐	☐	☐	

5. Findings and Risk Treatment

Rate each finding Critical, High, Medium or Low. Every condition requires an accountable owner, due date and closure evidence; open Critical or High findings block deployment unless the authorised governance route records an explicit exception.

Finding ID	Severity	Required action and closure evidence	Owner	Due date	Status
SEC-	Critical / High / Medium / Low	Action; acceptance or closure evidence reference			Open / Closed / Accepted
SEC-	Critical / High / Medium / Low	Action; acceptance or closure evidence reference			Open / Closed / Accepted
SEC-	Critical / High / Medium / Low	Action; acceptance or closure evidence reference			Open / Closed / Accepted

6. Review outcome

Outcome	Approved / Approved with conditions / Not approved
Conditions and required actions	Actions required before or after deployment, with owners and dates
Escalations raised	Matters referred to the AI Governance Working Group or Board

Finding ID	Severity	Required action and closure evidence	Owner	Due date	Status
Reviewer signature / date					
AI Register updated		Date the review outcome was recorded in the AI Register			
Residual security risk		Critical / High / Medium / Low — rationale and evidence reference			
Risk acceptance required?		Yes / No; identify the exception to policy or risk tolerance			
Risk acceptance authority		Authorised Council risk owner name, role and delegated authority; reviewer must not self-accept			
Risk acceptance decision / date / expiry		Accepted / Rejected; conditions, date, expiry and mandatory review trigger			
Risk acceptance evidence		Delegated Council decision in AIG-DEC-03 and gate event in AIG-DEC-04; Board assurance opinion if required.			
Deployment-block check		No open Critical/High findings or unapproved exceptions — confirmed by reviewer and governance approver			

A completed AI Security Review does not certify a system as risk-free. Security events occurring after deployment trigger governance escalation regardless of this outcome (Playbook §3.10.3).

Agentic security coverage for action-capable systems

For each ASI risk below, the security reviewer records Applicable / Not applicable with rationale, accountable control owner, required state, actual state (Designed / Specified / Implemented / Evidenced), a test outcome and dated evidence reference. Record the full result under the AIR-ID in the review findings and AIG-AGT-04 Runtime Controls, reusing existing evidence rather than completing ten separate forms. A document describing a control is not a passed test.

ASI01 Agent Goal Hijack — test untrusted input or retrieved content attempting to alter the authorised goal; show rejected action and trace.

ASI02 Tool Misuse — exercise out-of-scope tool action, transaction limits and approval thresholds; show denied tool call and audit trail.

ASI03 Identity and Privilege Abuse — verify distinct identity, least privilege, delegation ceiling, token expiry and revocation.

ASI04 Agentic Supply Chain Vulnerabilities — verify provenance and approval of models, tools, connectors, MCP servers and component versions; test an unapproved change.

ASI05 Unexpected Code Execution — attempt prohibited code or shell execution; verify sandbox, permissions and egress boundaries where code execution is applicable.

ASI06 Memory and Context Poisoning — test hostile memory or retrieval content, write approval, isolation, provenance and deletion where persistent or shared memory applies.

ASI07 Insecure Inter-Agent Communication — test sender identity, message integrity, authorised delegation and cross-agent trust boundaries where agents communicate.

ASI08 Cascading Failures — test transaction, rate, recursion and budget limits, circuit breaker and chain-wide containment.

ASI09 Human-Agent Trust Exploitation — test that a misleading agent explanation cannot bypass human review of evidence or approval conditions.

ASI10 Rogue Agents — test goal drift, unauthorised persistence or replication, stop/revoke and evidence reconstruction.

Security review conclusion: list failed or untested applicable controls as findings with owners, treatment and due dates.

Consequential production autonomy cannot be marked Approved/Active on design claims alone. Where required controls lack Implemented and Evidenced status, only a specific effective, time-bounded compensating control expressly accepted under Council delegation may permit the scoped operation; refer to AIG-DEC-03, AIG-OPS-01, AIG-DEC-04 and AIG-AGT-04. AI Assurance Board advice does not itself authorise a system.

Source: OWASP Top 10 for Agentic Applications 2026 (genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/).

This checklist maps security risks to Council evidence; OWASP does not approve a Council deployment.

Document control

Administrative control record. This artefact remains a working draft until formally approved.

Field	Controlled value
Document ID	AIG-ASS-11
Version	1.3 draft
Status	Draft for council review
Document owner	Information and Cyber Security
Approving body	Pending confirmation — Competent Council authority under Constitution and Scheme of Delegation; AI Assurance Board provides assurance where applicable; exact delegation and publication authority to be verified by Monitoring Officer.

Field	Controlled value
Approval date	Not yet approved
Effective date	Not yet effective
Next review date	To be set on approval: 12 months after the effective date, or sooner following material change
Classification	OFFICIAL

Change history

Version	Date	Change summary	Owner
1.0 draft	6 August 2026	Document-control baseline established following full-suite quality assurance; no substantive content change.	Information and Cyber Security
1.1 draft	6 August 2026	QA revision: added supplier-security, findings, severity, due-date and risk-acceptance controls.	Information and Cyber Security
1.2 draft	6 August 2026	Controlled identifier and filename renumbered from 21 to 20 to create a continuous 00–20 suite sequence; security-control content unchanged.	Information and Cyber Security
1.3 draft	25 September 2026	Mapped ASI01–ASI10 to proportionate test evidence; corrected approving body.	Information and Cyber Security

Annex — Security identity, permissions and runtime evidence

PROPOSED INTEGRATION ONLY — This annex supplements the preserved source artefact; it does not amend or replace original text or tables and is not approved policy or permission to operate.

Identity and exact version

- Record permanent AIR-ID plus the individual agent's stable AG-ID. Cite the exact AIG-AGT-04 ASBOM version/revision and identifiable snapshot/effective reference; "current/latest" is insufficient. A pre-registration discovery reference is provisional, not AIR-ID; governance assigns AIR-ID upon Register (AIG-INV-04) registration.

Permissions and security controls

- ASBOM (AIG-AGT-04) is authoritative for actual permissions, capabilities, components, tools/interfaces, delegated authority, constraints, approvals, revocation and runtime-control state. Graph (AIG-AGT-05) depicts edges derived from the ASBOM Authority & Delegations sheet; it is not an independent permission source. Resolve discrepancies against the cited ASBOM version.
- Verify technical enforcement, not documentation alone: unique authenticated identity, least privilege/scoped credentials, distinct read/write/execute scopes, transaction/rate/delegation ceilings, environment/interface restrictions, approval thresholds, secrets handling, expiry/revocation and tested containment/stop controls. Prompts, memory, intent or a graph edge do not grant permission. For applicable ASI controls, retain owner, required/actual state, test result and dated evidence; mark Implemented/Evidenced only where operational enforcement and tests support it.

Action evidence and links

- AIG-AGT-06 must link each consequential action's unique Action ID and execution/log evidence to AIR-ID, AG-ID and the exact ASBOM version used to check authority. Evidence covers authority, action/tool, timestamp, approval/override, outcome, reversibility and relevant controls, without private chain-of-thought.
- Cross-reference Action ID in AIG-OPS-03 for incident, AIG-OPS-02 for monitoring/review and AIG-DEC-04 for relevant gate condition/decision/follow-up. They are links as applicable; AIG-AGT-06 is execution evidence, not permission, risk acceptance or a gate decision. Material changes, failed controls or unexpected action require escalation and applicable full Intake (AIG-INV-03)/triage re-entry.

Status of this proposed copy

Proposed map use in security scoping

If AIG-INV-05 is adopted, use version-specific component pointers as a discovery aid when scoping security review, then validate them against authoritative inventory/configuration sources. The map is not an access-control inventory or security evidence. For agent/tool permissions and delegation resolve exact AIG-AGT-04 ASBOM records and AIG-AGT-05 derived paths; record tests/findings in the security control and link any actual AIG-DEC-04 Gate Event/Condition separately.

Proposed integrated draft; not approved and not effective. Original baseline content and tables are retained above. Formal approval, owner confirmation and document-control updates remain for the competent Council authority.

Standards and legal applicability — proposed QA cross-reference

PROPOSED QA INDEX — NOT APPROVED LEGAL ADVICE OR EVIDENCE OF COMPLIANCE. The listed instruments may be relevant to this artefact, but applicability depends on the case, service and Council delegation. Legislation, official guidance, Council policy and voluntary standards are different authority classes. The full 51-entry requirement inventory, authoritative URLs, validation owners and current versions are in AIG-AIMS-05; source checks are in AIG-AIMS-13. Do not treat a template, plan or cross-reference as completed assessment, adopted policy, ISO conformity or legal sign-off.

Requirement / instrument	Why check it here	Source
REQ-001 — UK General Data Protection Regulation (UK GDPR), as amended	Where personal data is processed; test each UK GDPR provision separately.	https://www.legislation.gov.uk/eur/2016/679/contents
REQ-023 — Computer Misuse Act 1990	Screen the legislation requirement against this artefact's actual use and record evidence/version; see REQ-023.	https://www.legislation.gov.uk/ukpga/1990/18/contents
REQ-024 — Network and Information Systems Regulations 2018 (NIS Regulations)	Screen the legislation requirement against this artefact's actual use and record evidence/version; see REQ-024.	https://www.legislation.gov.uk/uksi/2018/506/contents
REQ-039 — NCSC Guidelines for Secure AI System Development	Screen the government security guidance requirement against this artefact's actual use and record evidence/version; see REQ-039.	https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development/introduction
REQ-047 — Council cyber security, acceptable use, identity/access, secure development, incident, resilience and business-continuity policies	Screen the council policies / standards requirement against this artefact's actual use and record evidence/version; see REQ-047.	Council controlled security and resilience repository — authoritative titles, versions and links to be populated
OWASP-ACS-2026 — OWASP Agent Control Standard (source edition/date to confirm)	Technical design guidance; verify edition and operational tests	https://genai.owasp.org/resource/agent-control-standard-acsf/